SPIKA TECH™

PROCEDIMIENTO DE SEGREGACIÓN DE REDES Y FLUJOS DE INFORMACIÓN

HISTORIAL DEL DOCUMENTO			
Versión	**Resumen de modificaciones**	**Fecha de entrada**	**Sustituye a (Código, revisión)**
01	Primera versión del documento.	12/03/2025	N/A

REGISTRO DE FIRMAS			
Función:	**Elaborado por:**	**Revisado por:**	**Aprobado por:**
Departamento:	Responsable del SGSI	Dirección	Jefe de seguridad (o suplente)
Nombre:	David Pozo	Carlos Rodrigo	Carlos Zúñiga
Firma:	Firmado por POZO SANCHEZ DAVID - ***6992** el día 12/03/2025	Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) el día 13/03/2025	Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 13/03/2025 con un
Fecha:	12/03/2025	12/03/2025	12/03/2025

CONTENIDO

1 OBJETIVO 4
2 ALCANCE 4
3 NORMATIVA APLICABLE 4
4 ROLES 4
5 GESTIÓN DE LAS COMUNICACIONES 4
5.1 Controles de red 5
5.2 Controles técnicos 5
5.3 Segregación de redes 6
5.4 Protección de redes de área local 7
5.5 Protección de redes extensa 8
5.6 Protección de redes inalámbricas 8
6 GESTIÓN DE PERMISOS EN RED 9
7 REFERENCIAS 9
¡Error! Marcador no definido.

1 OBJETIVO

El objeto del presente documento es establecer las medidas de seguridad oportunas que permitan fortalecer las redes de comunicación de SPIKA TECH. Es esencial que se fijen los mecanismos que protejan la confidencialidad, integridad y disponibilidad de la información que transcurren por las redes de SPIKA TECH, describiéndose para ello en el presente procedimiento las medidas técnicas y organizativas a seguir.

2 ALCANCE

Este procedimiento se aplica en todos los sistemas de información que dan soporte a los servicios de SPIKA TECH. Asimismo, es de obligado cumplimiento para todos aquellos usuarios que, de manera permanente o eventual, presten sus servicios dentro de SPIKA TECH y cuando manejen sistemas de redes y comunicaciones que queden bajo el alcance del presente procedimiento.

3 NORMATIVA APLICABLE

Es aplicable toda la normativa establecida en el documento de **RGS_1 NORMATIVA APLICABLE**, que se actualizara de forma periódica Las Políticas, Normas y Procedimientos dentro del alcance.

4 ROLES

- **Área de ciberseguridad:**
  - Realizar la configuración de los equipos de comunicaciones.
  - Realizar la monitorización de las redes de comunicaciones.
  - Realizar las gestiones que correspondan sobre permisos de usuarios.
  - Establecer las directrices de seguridad de equipos.

5 GESTIÓN DE LAS COMUNICACIONES

Las redes y comunicaciones de SPIKA TECH deben proteger la confidencialidad, integridad y disponibilidad de la información transmitida a través de la infraestructura de comunicaciones

existente, lo que se obtiene a través de la implantación de controles específicos, la aplicación de medidas de seguridad a los servicios de red y una correcta segmentación de redes si es necesario.

5.1 Controles de red

Con el fin de asegurar la protección de las redes de comunicación de SPIKA TECH se han establecido las siguientes directrices de seguridad con el fin de gestionar y controlar de forma segura y adecuada las redes:

- Segregar adecuadamente las responsabilidades de usuarios sobre las redes de datos y los sistemas, siempre que así sea posible, especialmente en los procedimientos definidos para la gestión de los equipos de red.
- Implantar controles de red destinados a proteger la confidencialidad e integridad de la información en tránsito por las redes, así como la disponibilidad del servicio.
- Establecer procedimientos formales para la gestión de equipos de forma remota, indicando responsabilidades.
- Definir las responsabilidades para la implantación, gestión y mantenimiento de los elementos que forman la red de SPIKA TECH.

5.2 Controles técnicos

Los controles de seguridad de que dispone SPIKA TECH implantados a nivel de red, son:

- **Sistema EDR en equipos Windows** que registran cualquier detección, eliminación, infección o comportamiento anómalo en el sistema.
- **Antivirus:** Los puestos de usuario deberán contar con software antivirus operativo, siendo de vital importancia mantener actualizadas conforme a la política establecida las definiciones de virus. El antivirus deberá estar configurado para identificar amenazas antes de su ejecución en memoria, protegiendo así fuentes de infección como el correo electrónico, la navegación web, el intercambio de ficheros por red o mediante dispositivos, etc.
- **Sistema de prevención y detección de intrusiones (IDS e IPS) del firewall:** Se lleva a cabo un análisis en tiempo real de las conexiones y protocolos, con el objetivo de identificar ataques según patrones, anomalías o comportamientos sospechosos,

implementado políticas que se basan en el contenido del tráfico monitorizado. Se generan registros detallados del tráfico existente en la red SPIKA TECH, tanto del tráfico que ha sido permitido, como bloqueado, según las reglas establecidas para ello.

- **Cortafuegos de Aplicaciones Web (WAF):** Se protegerán las aplicaciones web de determinados ataques específicos en internet, de esta forma se filtran, supervisan y se analiza el tráfico de protocolo de transferencia seguro (HTTP) y del protocolo de transferencia de hipertexto seguro (HTTPS) entre las aplicaciones web e internet. Entre los ataques que se mitigan, se encuentran:
    - Ataques de denegación de servicios (DoS).
    - Ataques maliciosos.
    - Ataques de inyección.
    - Exposición de ataques sensibles.
- **Sistemas de Acceso Remoto (VPN):** Se registran todos los accesos, tanto los permitidos como los fallidos, detallándose la fecha y hora en la que tuvieron lugar.

5.3 Segregación de redes

La segregación de redes es una medida de seguridad cuyo objetivo es segregar grupos de servicios de información, usuarios y sistemas de información en distintos dominios mediante la división de la red de la organización en tantas subredes como se consideren necesarias. Esta división de la red puede realizarse de manera física (por ejemplo, mediante el uso de cortafuegos, switches y otros dispositivos de red) y lógica (por ejemplo, mediante la implantación de redes locales virtuales), teniendo en cuenta en cada caso los requisitos de seguridad y los controles de acceso definidos, así como la clasificación de la información en uso dentro de la subred.

El procedimiento de segregación de redes debe permitir segregar grupos de servicios de información, usuarios y sistemas a través de distintos dominios. Para cumplir con este requisito se deberá:

- Definir el procedimiento en base los resultados de un análisis de riesgos realizado con carácter previo a la ejecución del procedimiento, en base al dominio propio de cada subred.

- Desplegar la arquitectura de las aplicaciones en los distintos segmentos de red, aplicando seguridad en profundidad, alojando, por tanto, los datos más sensibles en las capas más internas.
- Configurar los dominios de la red para filtrar el tráfico y bloquear los intentos de acceso no autorizados entre dominios, de acuerdo con las necesidades de negocio.
- Configurar las pasarelas de seguridad entre dominios de la red de tal manera que filtren el tráfico y bloqueen intentos de acceso no autorizados entre los mismos.
- Cifrar las comunicaciones entre los distintos segmentos de red cuando se detecte la necesidad.

5.4 Protección de redes de área local

Se deberán aplicar los siguientes controles

- A nivel de seguridad física y del entorno:
  - Utilizar cables y candados de seguridad para evitar robo de equipos.
  - Asegurarse de que los hubs y routers de alta importancia se encuentran en armarios seguros y cerrados con llave.
  - Proporcionar SAIs a todos los dispositivos de red críticos, así como a Servidores y otro equipamiento que pueda contener información relevante.
- A nivel de hardware y software:
  - Establecer políticas de contraseñas robustas en el acceso a cualquier dispositivo.
  - Requerir procesos de login en cada equipo de usuario. Deshabilitar puertos USB, grabadoras de CD, y controlar los dispositivos que estén autorizados.
  - Eliminar cualquier software sin licencia o no necesario.
- A nivel operativo:
  - Asegurar que se haya cambiado las contraseñas por defecto de hubs y switches.
  - Activar los logs de auditoría adecuadamente, implantando los procedimientos de monitorización correspondientes.
  - Programar la instalación periódica de firmware en los dispositivos.

- Documentar las configuraciones de cada equipo de red, realizando backups de las mismas.

5.5 Protección de redes extensa

Se deberán aplicar los siguientes controles:

- Utilizar protocolos seguros (ssh, sftp, …).
- Ubicar el equipamiento de la red en armarios seguros y cerrados con llave.
- Emplear rutas replicadas entre sites.
- Realizar pruebas continuas de los dispositivos existentes en la red, en búsqueda de elementos no autorizados.
- Establecer conexiones cifradas cuando se transmita información sensible o que contenga datos personales.
- Emplear firewalls para separar redes de diferentes entornos y poder filtrar el tráfico no deseado.
- Ocultar las direcciones privadas de la red al enviar tráfico a redes externas.
- No asignar direccionamiento público en los equipos de la red.
- Emplear IDS para identificar tráfico sospechoso.
- Separar la gestión y la administración de la red de la operativa.

5.6 Protección de redes inalámbricas

En SPIKA TECH existe la posibilidad de conectar sin cables a través de las redes WiFi. Para que dichas conexiones sean seguras, se deberán aplicar los siguientes controles:

- Identificar los tipos de servicios que se proporcionan a través de este medio.
- Identificar al personal técnico autorizado para instalar y configurar los puntos de acceso y otro equipamiento inalámbrico.
- Identificar las limitaciones físicas de la red, así como los mecanismos para protegerla frente a los ataques físicos.

- Describir el tipo de información que puede enviarse a través de los enlaces inalámbricos.
- Definir los estándares, respecto al hardware, que son admitidos para su uso y operación.
- Describir los estándares, respecto a la configuración que debe ser implementada en los dispositivos inalámbricos.
- Describir las limitaciones de uso de dispositivos inalámbricos, incluyendo ubicaciones específicas.
- Establecer normas para minimizar el riesgo frente a robos en los dispositivos. Realizar periódicamente auditorias técnicas de seguridad con el fin de detectar vulnerabilidades y solucionarlas.
- Aplicar las normas sobre el uso de técnicas de cifrado y la gestión de claves, establecidas por los procedimientos oportunos.

En el momento de configurar la red, el área de Comunicaciones valorará aplicar las siguientes medidas de seguridad:

- Configuración de cuentas de acceso administrativas, cifrado, ACLs, claves compartidas, ocultación de SSID, desactivación de DHCP, y protocolo SNMP.
- Implementación de firewalls personales en cada dispositivo para evitar accesos no autorizados desde otros dispositivos no autorizados.

6 GESTIÓN DE PERMISOS EN RED

La gestión de permisos de red se realiza siguiendo lo establecido en el **Procedimiento de control de acceso de usuarios**. Se debe tener en cuenta que los usuarios sólo tendrán acceso a aquellos servicios de red que sean necesarios para desempeñar sus funciones. Además, también está establecido que dichos permisos deban periódicamente para comprobar si siguen siendo necesarios.

7 REFERENCIAS

- ISO 27001:2022:
    - 8.20 Seguridad de redes

- 8.21 Seguridad de los servicios de red
- 8.22 Segregación en redes